

Core Concepts — Why AI Governance, and the Frameworks That Structure It

Part 12 —  AI Governance · 12-ai-governance/notes/01-governance-fundamentals-and-frameworks.md

1. Why this is not just IT governance with a new logo

Your organization already has change management, a risk register, a vendor security review, and an incident process. The instinct — reasonable, wrong — is to route AI through the existing machinery unchanged. Four properties of modern AI systems break that machinery's assumptions.

1. It is confidently wrong, on purpose. Traditional software fails loudly: a null pointer, a 500, a stack trace. An LLM fails *fluently* — it produces a well-formed, grammatically confident, plausible answer that is simply false, and nothing in the output signals that. Code review catches a bug because the bug looks wrong. A hallucinated citation looks exactly like a real one. Governance has to assume the failure mode is invisible at the point of production, which is why evaluation (Module 15) and human oversight design (§6 of the companion note) exist as *governance controls*, not engineering nice-to-haves.

2. Behavior is emergent, not specified. You did not write the rule that decided the chatbot's tone, or the exact conditions under which an agent decides to call a refund tool. You wrote a prompt and picked a model, and behavior emerged from training data and weights you don't have visibility into. Traditional IT risk assessment asks "what does this code do?" and reads the code. You cannot read an LLM's weights and answer that question — you can only *test* the behavior empirically, exhaustively, and repeatedly, because the next prompt tweak or model version can shift it again.

3. Agentic systems act, they don't just answer. Module 06 and Module 07 covered agents that call tools, chain decisions, and take actions with side effects (send an email, issue a refund, modify a record). The risk surface of "the system might say something wrong" is bounded; the risk surface of "the system might *do* something wrong, autonomously, in a loop" is not. Governance for agentic AI has to reason about action authority, not just output quality — this is why human-oversight posture (§6 of the companion note) is tiered by autonomy, not just by output sensitivity.

4. You don't own the supply chain, and you often don't own the weights. Most organizations building AI products today are calling a third-party model API, embedding a vendor's AI feature, or wiring in an MCP server (Module 09) someone else wrote. You cannot audit training data you never saw, you cannot patch a foundation model's bias, and a silent version bump on someone else's endpoint can change your product's behavior with zero commits on your side. Traditional vendor risk management assumes a vendor ships you a defined, versioned artifact. An AI vendor ships you a moving target. §7 of the companion note covers the vendor-risk approach this requires.

The one-sentence version: traditional software risk management assumes deterministic, inspectable, version-pinned behavior under your control. AI systems are probabilistic, opaque, and frequently rented.

Every governance control in this module is a response to one of those four gaps.

None of this means "throw out IT governance." It means AI governance sits *on top of* IT governance, adding the controls that address what's structurally new, while reusing what already works (access control, SDLC, incident management processes) for what hasn't changed.

2. The NIST AI Risk Management Framework (AI RMF 1.0)

Published by NIST in January 2023 (NIST AI 100-1), the AI RMF is **voluntary, non-prescriptive guidance** — it tells you what to think about, not which specific control to implement. It is organized around four functions. Note that unlike the other three, **Govern is cross-cutting**: it doesn't run once at the start, it wraps and enables the other three continuously.

Function	What it actually asks	Practical output
Govern	Do we have policy, accountability, and a risk-management culture <i>before</i> we build anything?	Charter, committee, named accountable roles, risk-tolerance statement, third-party risk policy
Map	What is this specific system, for what purpose, in what context, affecting whom?	Use-case inventory entry, intended-use statement, stakeholder/impact list
Measure	Does it actually perform, and is it trustworthy (safe, fair, accountable, explainable, robust)?	Eval results, bias testing, red-team findings — feeds Module 15 directly
Manage	Given what we measured, what do we prioritize, mitigate, monitor, or kill?	Risk treatment plan, monitoring plan, incident/response procedure, go/no-go decision

Each function decomposes into categories and subcategories (Govern has 6 categories/19 subcategories; Map 5/14; Measure 4/13; Manage 4/9) — think of these as a checklist bank, not a certification. NIST also publishes a **Playbook** (suggested actions per subcategory, meant to be adapted, not copied verbatim) and the concept of **Profiles** — a tailored subset of the framework for your sector or use case (NIST has published a Generative AI Profile as a companion). There is no certificate at the end. You adopt the AI RMF by mapping your existing (or new) controls onto its four functions and using the gaps you find as your initial risk-register backlog.

What an organization actually does with it, concretely: - Stand up the Govern function first — usually as the charter for the governance committee in §4 of the companion note — because Map/Measure/Manage activities have nowhere to report into without it. - Use Map as the intake form for the AI use-case inventory: every new AI project gets a Map entry before a line of production code is written. - Route Measure to whoever owns evaluation (Module 15) — this is where "trustworthy AI characteristics" (validity, reliability, safety, fairness, explainability, privacy, security) turn into actual test suites. - Use Manage as the trigger for the risk-tiering exercise in §3 below: a Measure finding that fails a threshold becomes a Manage decision (mitigate, accept, or kill).

3. ISO/IEC 42001:2023 — the AI Management System standard

Where the AI RMF is a voluntary thinking tool, ISO/IEC 42001 is a **certifiable management-system standard** — the AI-specific sibling of ISO 27001 (information security) and ISO 9001 (quality). Published December 2023, it specifies requirements for establishing, implementing, maintaining, and continually improving an **AI Management System (AIMS)** within an organization, and an accredited body can audit and certify you against it.

It uses ISO's Harmonized Structure, so if you already run ISO 27001 you will recognize the shape immediately — the same Plan-Do-Check-Act cycle, the same clause numbers 4 through 10:

Clause	PDCA phase	Covers
4 — Context of the organization	Plan	Internal/external issues, interested parties, AIMS scope
5 — Leadership	Plan	Top-management commitment, AI policy, roles & responsibilities
6 — Planning	Plan	AI risk assessment, AI impact assessment, objectives
7 — Support	Plan	Resources, competence, awareness, documented information
8 — Operation	Do	Operational planning across the AI system lifecycle
9 — Performance evaluation	Check	Monitoring, internal audit, management review
10 — Improvement	Act	Nonconformity handling, corrective action, continual improvement

Annex A lists 38 reference controls, organized by topic (AI policy; internal organization, roles & responsibilities; resources including data and compute; the AI system lifecycle; impact assessment; third-party and customer relationships; use of AI systems). As with ISO 27001's Annex A, you don't have to implement every control — you run a risk and impact assessment (Clause 6) and produce a **Statement of Applicability** justifying which controls apply and which are excluded.

What an organization actually does with it, concretely: ISO/IEC 42001 is what you reach for when a customer, regulator, or procurement process wants third-party-audited proof that you *run* an AI management system, not just that you have good intentions. It is heavier to stand up than an AI RMF mapping — it requires document control, internal audits, and management review on a cadence — but the certificate is portable evidence you can hand to every customer at once instead of answering the same security questionnaire 40 times.

4. Choosing a framework (or both)

These are not competitors. Most mature programs run AI RMF-style thinking internally (it's free, flexible, and a genuinely good checklist) and pursue ISO/IEC 42001 certification only when there's an external audience that needs the certificate.

	NIST AI RMF	ISO/IEC 42001	EU AI Act (see Module 14 [12-ai-governance/14-ai-compliance])
Nature	Voluntary guidance	Certifiable management-system standard	Binding law (EU market)
Unit of analysis	A function (Govern/Map/Measure/Manage) applied per system	A management system across the org	A specific AI system's risk tier
Proves what	"We thought about this systematically"	"An accredited auditor verified our AIMS"	"We are legally permitted to place this on the EU market"
Cost to adopt	Low — a mapping exercise and a policy	Medium-high — certification audit, ongoing surveillance audits	Mandatory if in scope; cost = compliance program
Best first move for	Any org starting from zero	An org that already runs ISO 27001 and needs a customer-facing credential	Any org selling into the EU with a high-risk use case
Adopt it when	You need internal structure fast, no external audience yet	Customers/regulators demand third-party proof	You're in scope per Module 14's applicability test

A pragmatic sequencing for most mid-size companies: use AI RMF functions to structure the governance committee and risk register in month one (free, fast); layer EU AI Act risk tiering on top the moment any use case might touch EU users or employees (Module 14 owns this); pursue ISO/IEC 42001 certification only once you have enough real AI systems in production that a customer's security team is asking for it by name.

5. Risk tiering: the mechanic every framework converges on

Strip away the acronyms and every framework above is doing the same thing: **sort AI use cases into tiers, apply proportional controls, spend your scarce governance attention on the tiers that can actually hurt someone**. This is also, not coincidentally, the EU AI Act's core mechanic (unacceptable / high-risk / limited-risk / minimal-risk — see Module 14 [12-ai-governance/14-ai-compliance] for the legal specifics and which Annex III use cases land where). The internal-governance version of tiering doesn't need to match the law's exact categories, but it should use the same underlying logic, because by the time a regulator asks "how did you classify this system," "the same way we classify everything else, consistently" is the answer you want to give.

The four attributes that actually predict harm

A risk score built from a single "is this AI or not" checkbox is useless — a spell-checker and an autonomous fraud-blocking system are not the same risk, even though both are "AI." Four attributes carry almost all of the signal:

Attribute	Low end	High end	Why it matters
Data sensitivity	Public information, no personal data	Special-category data (health, biometric, protected-class, children's data)	Determines privacy/legal exposure and regulatory scope
Decision autonomy	Advisory only, human decides	Fully autonomous, no practical override	Determines how much of the harm the system can cause <i>before anyone notices</i>
Affected-population size	A handful of internal users	General public / systemic reach	Determines blast radius — a rare failure at scale is still a lot of harmed people
Reversibility of harm	Trivially corrected (edit and resend)	Irreversible (denied employment, incorrect medical triage, wrongful account closure)	Determines whether a mistake is a bug ticket or a lawsuit

`code/ai_risk_register_template.py` implements exactly this model: a transparent weighted score across these four axes, mapped to four tiers, run against six realistic use cases so you can see *why* a resume-screening tool and a marketing-copy generator land in wildly different places even though both are "just an LLM call." Run it before you read further — the point lands faster from output than from prose.

Proportional controls, not one-size-fits-all

The entire reason to tier is so a low-risk internal tool doesn't drag the same review machinery as a customer-facing credit decision. A rough shape most programs converge on:

Tier	Example	Review required	Ongoing obligation
Minimal	Internal code-completion assistant, marketing draft generator	Self-attestation, logged in the AI inventory	Standard engineering practice: version control, basic evals
Limited	Customer FAQ chatbot with human-reviewed escalation	Business-owner sign-off + AI inventory entry	Model card, usage monitoring, periodic spot-check
High	Fraud-detection flagging, resume screening, credit-adjacent scoring	Governance committee + model risk management review	Full model card, bias testing, mandatory human oversight, quarterly re-assessment
Critical	Medical triage guidance, autonomous financial transaction blocking	Executive/board sign-off, independent validation	Continuous monitoring, human-in-command design, incident response plan, named accountable executive

The tier also determines *who* has to say yes — which is the subject of the next note.

6. Where this returns

Idea here	Where it returns
Risk tiering mechanic	Module 14 [12-ai-governance/14-ai-compliance] — EU AI Act's legal risk categories use the same logic with binding thresholds
"Confidently wrong" failure mode	Module 15 [12-ai-governance/15-ai-evals] — why eval suites exist, and what a good one catches
Agentic action authority	Module 07 [12-ai-governance/07-agentic-ai] — the autonomy spectrum this module tiers against
Third-party model/API risk	notes/02 [12-ai-governance/notes/02-operating-model-and-practice.md] §5 — vendor-risk assessment specifics
Measure function output	Module 15 [12-ai-governance/15-ai-evals] — the eval results a model card's evaluation section actually cites
MRM discipline borrowed from finance	notes/02 [12-ai-governance/notes/02-operating-model-and-practice.md] §2 — the operating model